

Course-End Project

Conducting Vulnerability Assessment and Penetration Testing on a Simulated Web Application Environment

Objective: Simulate penetration testing on a vulnerable machine and identify security weaknesses.

Target Application: Travel Blog (IP: 10.0.2.8)

Steps to be followed:

1. Setting up VMs.

1.1. Open the browser and download VulnVM.ova file from the below link

<https://onedrive.live.com/?redeem=aHR0cHM6Ly8xZm1zL3UvYy84N2FlNTk1NjI1ODNiYjZkL0VaNV8zc0o5U2M5SnNQUTdZcER5Zkl0QklwSWlBeDBza0cxZWRCZVNTOXFyYkE%5FZT00N21jOVQ&cid=87AE59562583BB6D&id=87AE59562583BB6D%21sc2de7f9e497d49cfb0f43b6290f27c1e&parId=87AE59562583BB6D%21s872aeaed2c7942b2906c00c7975fb25f&o=OneUp>

1.2. Open Virtual Box and import the ova file.

1.3. Change the network settings of VulnVM and Kali linux machines to the same NAT network.

1.4. Open both VMs, and in their terminals, check for their IPs and run **ping** command to confirm that they're both on the same network.

2. Finding flag 1

2.1. On Kali Linux VM open the terminal,

Run the below command to scan the target machine for network vulnerabilities

```
nmap -A 10.0.2.8
```

From the result, we observe that TCP ports 21, 22 and 80 are open.

FTP server is connected and anonymous login is allowed

Apache server is running on HTTP through port 80

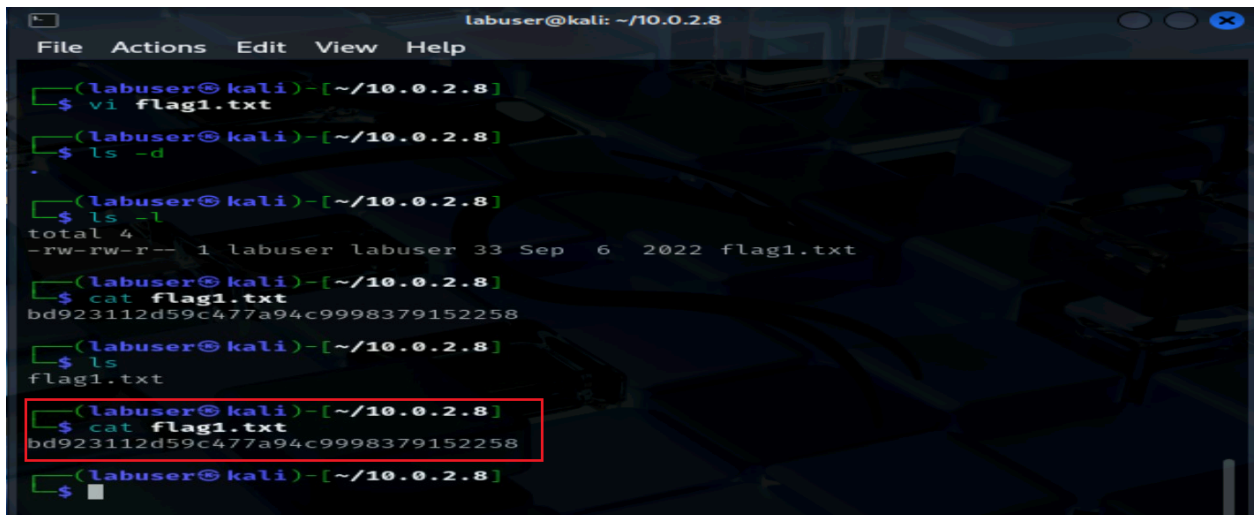
2.2. Run the below command to download files through FTP protocol.

```
wget -m --no-passive ftp://anonymous:anonymous@10.0.5.4
```

2.3. You can check the contents of the downloaded file using `cd` and `cat` commands

```
cd 10.0.2.8
```

```
cat flag1.txt
```

A screenshot of a terminal window titled 'labuser@kali: ~/10.0.2.8'. The terminal shows a series of commands and their outputs. The commands are: 'vi flag1.txt', 'ls -d', 'ls -l', 'cat flag1.txt', 'ls', and 'cat flag1.txt'. The output of 'ls -l' shows a file named 'flag1.txt' with permissions '-rw-rw-r--', owner 'labuser', group 'labuser', size '33', and date 'Sep 6 2022'. The output of 'cat flag1.txt' shows a long alphanumeric string: 'bd923112d59c477a94c9998379152258'. The last command 'cat flag1.txt' is highlighted with a red box.

```
labuser@kali: ~/10.0.2.8
File Actions Edit View Help

(labuser@kali)-[~/10.0.2.8]
$ vi flag1.txt

(labuser@kali)-[~/10.0.2.8]
$ ls -d
.

(labuser@kali)-[~/10.0.2.8]
$ ls -l
total 4
-rw-rw-r-- 1 labuser labuser 33 Sep 6 2022 flag1.txt

(labuser@kali)-[~/10.0.2.8]
$ cat flag1.txt
bd923112d59c477a94c9998379152258

(labuser@kali)-[~/10.0.2.8]
$ ls
flag1.txt

(labuser@kali)-[~/10.0.2.8]
$ cat flag1.txt
bd923112d59c477a94c9998379152258

(labuser@kali)-[~/10.0.2.8]
$
```

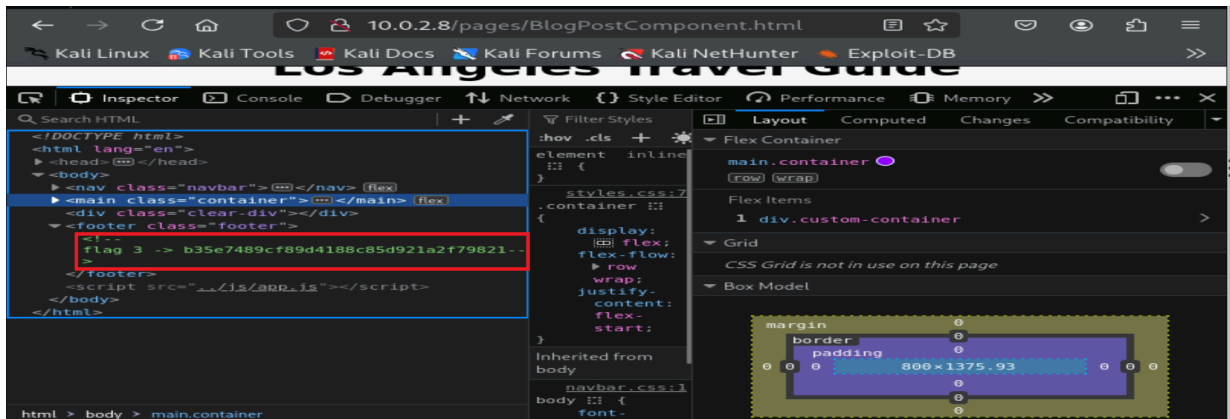
3. Finding flag 3

3.1. Access the Apache server on the browser with below link

```
http://10.0.2.8
```

It will open a travel blog website

- 3.2. Open the Blogs tab on the top right menu and click on read more... button of the summaries to open the full blog.
- 3.3. Use the shortcut buttons, Ctrl+U to see the source files. Here we can find the third flag



4. Finding flag 2

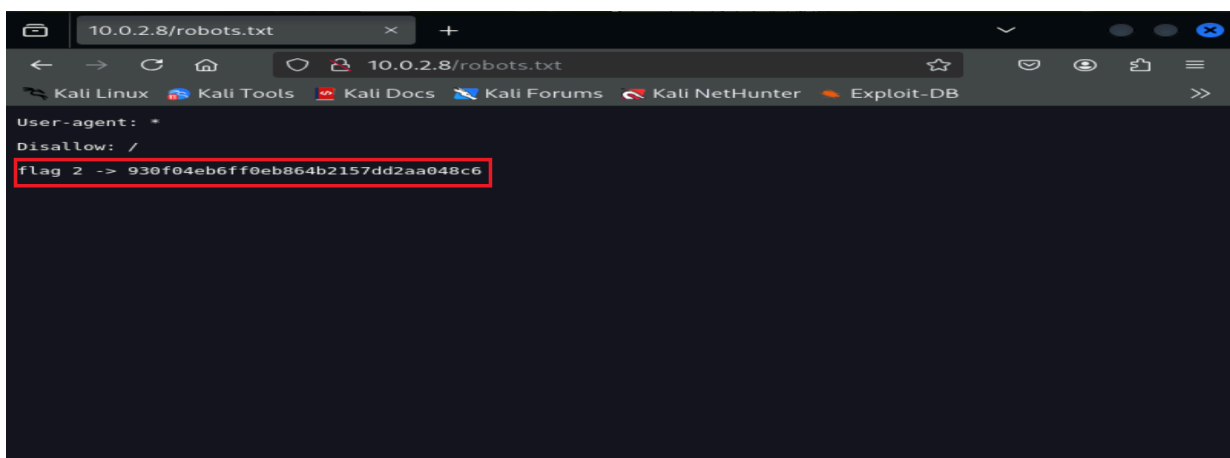
- 4.1. Use directory buster to get names of vulnerable files

```
gobuster dir -u http://10.0.2.5/ -w /usr/share/wordlists/dirb/common.txt -t 50
```

We can see for the file robots.txt http status us 200.

- 4.2. Access the file and we find the next flag.

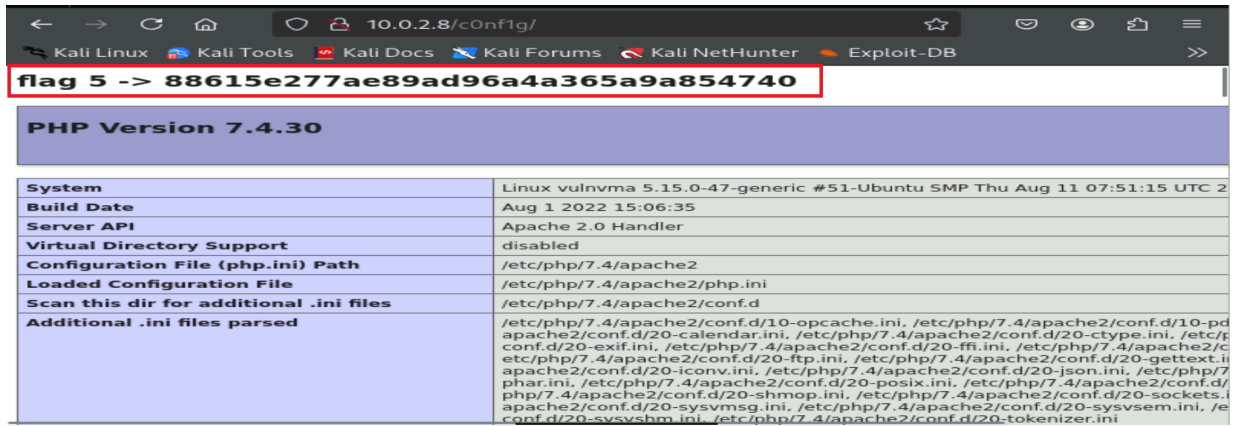
<http://10.0.2.8/robots.txt>



5. Finding flag 5

5.1. To access the config page we use the below link:

<http://10.0.2.8/c0nf1g>



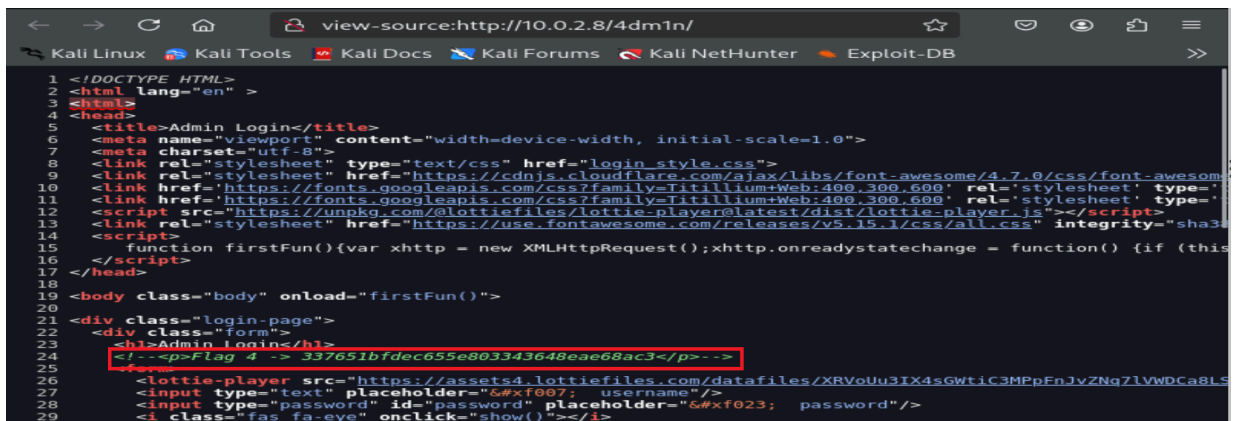
PHP Version 7.4.30	
System	Linux vulnvm 5.15.0-47-generic #51-Ubuntu SMP Thu Aug 11 07:51:15 UTC 2
Build Date	Aug 1 2022 15:06:35
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/apache2
Loaded Configuration File	/etc/php/7.4/apache2/php.ini
Scan this dir for additional .ini files	/etc/php/7.4/apache2/conf.d
Additional .ini files parsed	/etc/php/7.4/apache2/conf.d/10-opcache.ini, /etc/php/7.4/apache2/conf.d/10-pd apache2/conf.d/20-calendar.ini, /etc/php/7.4/apache2/conf.d/20-ctype.ini, /etc/p conf.d/20-exif.ini, /etc/php/7.4/apache2/conf.d/20-ffi.ini, /etc/php/7.4/apache2/c etc/php/7.4/apache2/conf.d/20-ftp.ini, /etc/php/7.4/apache2/conf.d/20-gettext.i apache2/conf.d/20-iconv.ini, /etc/php/7.4/apache2/conf.d/20-json.ini, /etc/php/7 phar.ini, /etc/php/7.4/apache2/conf.d/20-posix.ini, /etc/php/7.4/apache2/conf.d/ php/7.4/apache2/conf.d/20-shmop.ini, /etc/php/7.4/apache2/conf.d/20-sockets.i apache2/conf.d/20-sysvmsg.ini, /etc/php/7.4/apache2/conf.d/20-sysvsem.ini, /e conf.d/20-sysvshm.ini, /etc/php/7.4/apache2/conf.d/20-tokenizer.ini

6. Finding flag 4

6.1. To access the admin page we use the below link:

<http://10.0.2.8/4dm1n>

6.2. Once the page opens, use Ctrl+U to view the source and find the flag.



```
1 <!DOCTYPE HTML>
2 <html lang="en" >
3 <html>
4 <head>
5 <title>Admin Login</title>
6 <meta name="viewport" content="width=device-width, initial-scale=1.0">
7 <meta charset="utf-8">
8 <link rel="stylesheet" type="text/css" href="login_style.css">
9 <link rel="stylesheet" href="https://cdn.jsdelivr.net/npm/font-awesome@4.7.0/css/font-awesome.min.css">
10 <link href="https://fonts.googleapis.com/css?family=Titillium+Web:400,300,600" rel="stylesheet" type="text/css">
11 <link href="https://fonts.googleapis.com/css?family=Titillium+Web:400,300,600" rel="stylesheet" type="text/css">
12 <script src="https://unpkg.com/lottiefiles/lottie-player@latest/dist/lottie-player.js"></script>
13 <link rel="stylesheet" href="https://use.fontawesome.com/releases/v5.15.1/css/all.css" integrity="sha384-OVQ7D60023bd41VLQwR6BQQ7H236TA1JJ/5114w+98938484c6604770e8989b">
14 <script>
15 function firstFun(){var xhttp = new XMLHttpRequest();xhttp.onreadystatechange = function() {if (this
16 </script>
17 </head>
18
19 <body class="body" onload="firstFun()">
20
21 <div class="login-page">
22 <div class="form">
23 <h1>Admin Login</h1>
24 <p>Flag 4 -> 337651bfdec655e803343648eae68ac3</p>
25 <div>
26 <lottie-player src="https://assets4.lottiefiles.com/datafiles/XRVoUu3IX4sGwtiC3MPpFnJvZNq7lVWDCa8LS
27 <input type="text" placeholder="#x007; username"/>
28 <input type="password" id="password" placeholder="#x023; password"/>
29 <i class="fas fa-eye" onclick="show()"></i>
```

7. Finding flag 6

7.1. Configuring Burp Suite:

Open Burp Suite.

Go to Proxy → Intercept.

Turn on Intercept

7.2. Configuring Browser Proxy

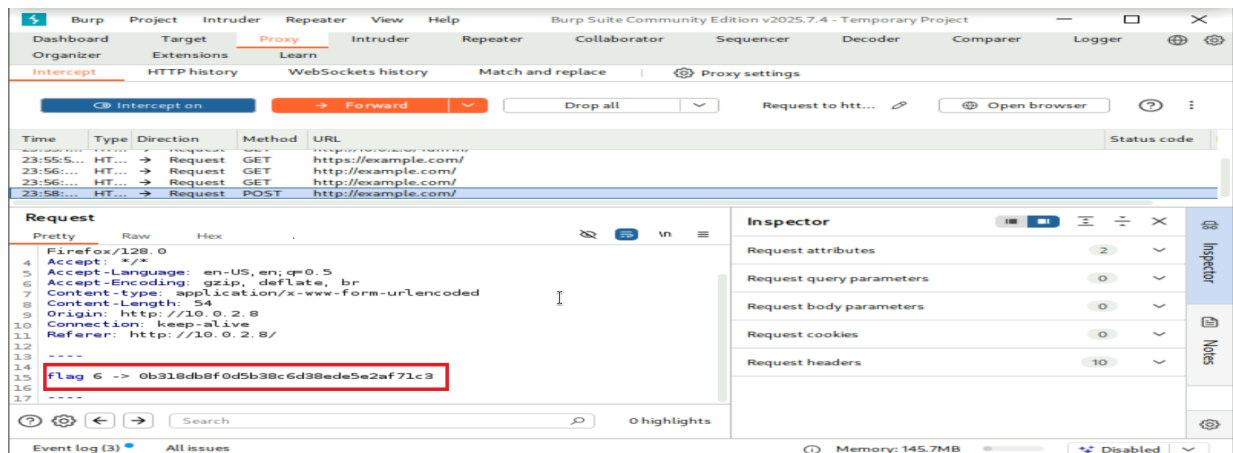
Open Firefox

Go to Settings → Network Settings → Manual proxy.

Set, HTTP Proxy: 127.0.0.1, Port: 8080

Enable Use this proxy for all protocols

7.3. Reload the admin website and you can see the next flag in Burp Suite



Findings and Recommendations

- **Open Ports and FTP Misconfiguration**

The FTP service was misconfigured to allow anonymous login, which enabled unauthorized users to access the server without valid credentials. This weakness was exploited to download sensitive files leading to information disclosure. To mitigate this risk, anonymous FTP access should be disabled and strong authentication mechanisms should be enforced to ensure only authorized users can connect.

- **Sensitive Data Exposure in Website Source Code**

Sensitive information was improperly embedded within the website's HTML source code, making it accessible to anyone who viewed the page source. This flaw allowed attackers to easily identify exposed data. To prevent such exposure, confidential information should never be included in client-side code, and secure web development practices must be followed.

- **Insecure Files and Directory Disclosure**

Improperly secured files and directories, including /robots.txt and /c0nf1g/, were publicly accessible due to weak access controls. Attackers used directory enumeration tools such as Gobuster to discover these paths and retrieve sensitive information. This issue can be mitigated by implementing strict access controls and restricting public access to sensitive directories and configuration files.

- **Weak Access Control in Admin Panel**

The administrative panel located at /4dm1n/ lacked adequate security controls, allowing unauthorized users to access protected resources. This vulnerability exposed sensitive information, and further manipulation using Burp Suite enabled additional data retrieval. To reduce this risk, administrative interfaces should be protected with strong authentication

mechanisms, including multi-factor authentication, and access should be limited to authorized users only.

- **Misconfigured Web Application and Directory Listing**

Directory listing was enabled on the web server, allowing attackers to browse internal directories and identify sensitive files and configurations. This misconfiguration increased the attack surface and facilitated information leakage. Disabling directory listing and restricting access to non-essential directories are necessary steps to prevent unauthorized file exposure.